



Au cœur de vos attentes. *En réponse à vos besoins*

Formation : *ASRS / TISR*

Module 2 : Collecte d'information, reconnaissance et social engineering.



Table des matières

- 1 : Prise d'empreinte passive (footprint)
- 2 : Prise d'empreinte active (fingerprint)
- 3 : L'ingénierie sociale
- 4 : Les contres mesures





Prise d'empreinte passive (footprinting)

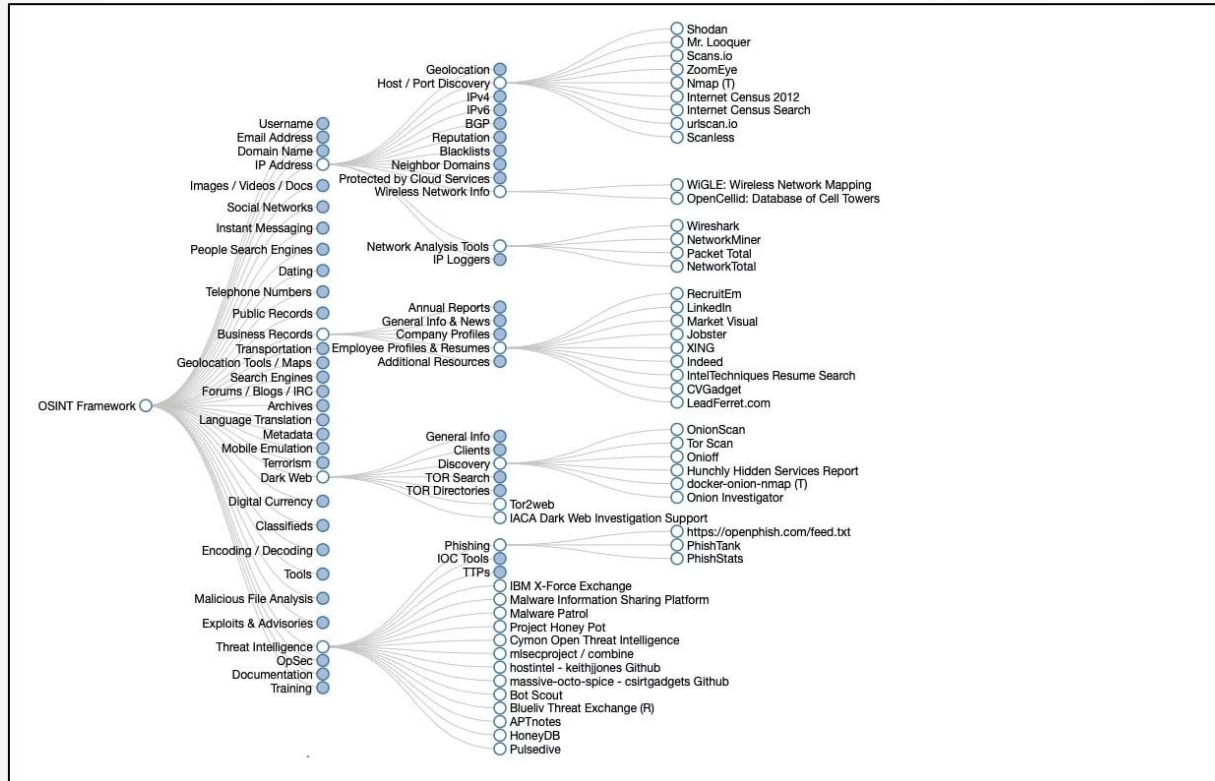


Qu'est ce que l'Open Source Intelligence ?

- C'est la collection de toute donnée de source publique et qui peut être utilisée dans un processus de reconnaissance.
- C'est la première étape de l'attaque dont le but est de trouver un maximum d'informations sur la cible afin d'identifier les différents points d'entrée pour s'introduire.
- Avoir une idée sur le niveau de sécurité de l'organisation cible vu de l'extérieur.



OSINT Framework



Les réseaux sociaux

Une source d'information plus qu'importante !

- Un hacker avait falsifié les empreintes digitales d'une ministre allemande en utilisant des photos de ses mains trouvées sur les réseaux sociaux.

Les information utiles:

- La ville de résidence
- Les membres de sa famille
- Une date de naissance
- L'intérêt de la cible pour ses animaux de compagnie, et leur dénomination.



Les pages jaunes



Les pages blanches

 PagesJaunes

PagesBlanches

Annuaire inversé

Se référencer

  Mon compte



PagesBlanches

Le service de recherche de particuliers

Qui : Marie Durand

 Où : Lille, Alsace, Bd Voltaire, ...



Les sites d'offres d'emplois



pôle emploi

MONSTER

indeed

Archive.org : La machine à remonter dans le temps

The screenshot displays the Internet Archive WayBack Machine interface. At the top, a navigation bar includes links for WEB, BOOKS, VIDEO, AUDIO, SOFTWARE, and IMAGES, along with user options like SIGN UP, LOG IN, and UPLOAD. Below this, a secondary bar contains links for ABOUT, BLOG, PROJECTS, HELP, DONATE, CONTACT, JOBS, VOLUNTEER, and PEOPLE. The main content area features the Internet Archive logo and a search bar containing 'e-catalyst.fr'. To the left of the search bar is a 'DONATE' button. Below the search bar, a 'Calendar' button is highlighted, followed by links for 'Collections', 'Changes', 'Summary', and 'Site Map'. A text line indicates that the site was saved 33 times between December 18, 2019, and April 5, 2021. At the bottom, a timeline shows years from 1998 to 2021, with a bar chart indicating the frequency of saves, showing a significant increase in 2021.

INTERNET ARCHIVE Explore more than 582 billion web pages saved over time

[DONATE](#) **WayBackMachine** [Results: 50 100 500](#)

[Calendar](#) · [Collections](#) ^{beta} · [Changes](#) ^{beta} · [Summary](#) · [Site Map](#)

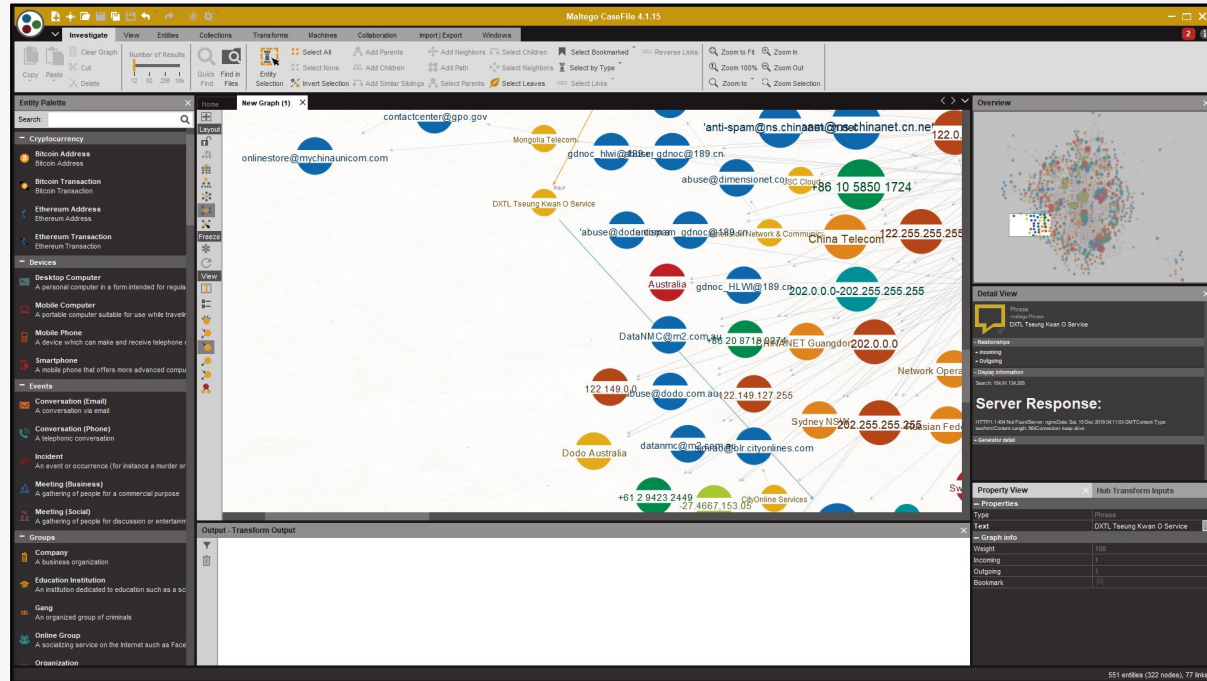
Saved **33 times** between [December 18, 2019](#) and [April 5, 2021](#).

Timeline: 1998 1999 2000 2001 2002 2003 2004 2005 2006 2007 2008 2009 2010 2011 2012 2013 2014 2015 2016 2017 2018 2019 2020 **2021**

- Une requête whois retourne les informations :
 - Détails du nom de domaine
 - Les informations de contact du propriétaire du domaine
 - Les serveurs DNS
 - La plage d'adresses
 - La date de création et expiration du domaine...
- Ces informations sont cruciales pour un attaquant s'il veut mettre en place un mode opératoire basé sur l'ingénierie sociale.
- Registre Internet Régional (RIR) et allocation de blocs d'adresses IP
 - RIPE-NCC, APNIC, ARIN, LACNIC, AFRINIC



Un outil permettant de déterminer les relations et les liens entre les personnes, entreprises, organisations...



L'enregistrement DNS

La syntaxe d'un enregistrement DNS: <name> <ttl> <class> <type> <rdlength> <rdata>

- <name> : le nom du domaine correspond à ce que l'internaute va taper dans son navigateur.
- <ttl> : TTL ou « Time to live » (durée de vie) désigne la durée (en secondes) pendant laquelle l'enregistrement DNS peut être conservé dans le cache. Après expiration de ce délai, il n'est pas certain que l'enregistrement de la ressource soit encore valide. Cette information est facultative.
- <class> : théoriquement, les DNS records sont répartis en plusieurs classes. Dans la réalité, la plupart des enregistrements DNS relèvent de la classe Internet (désignée comme IN). Cette information est donc facultative.
- <type>: un fichier de zone renferme plusieurs types d'enregistrements de ressources (plus de précisions sont données un peu plus bas).
- <rdlength> : ce champ facultatif précise la taille en octets du champ de données suivant.
- <rdata> : les données de ressources sont les informations à partir desquelles on va résoudre le nom du domaine, par exemple son adresse IP

L'enregistrement DNS

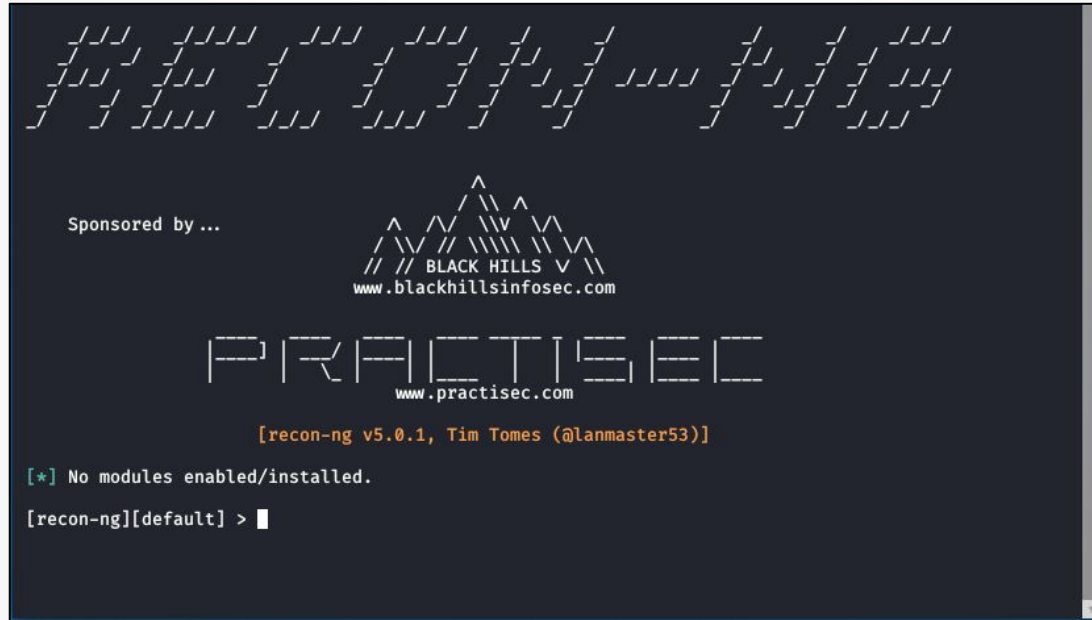
Les enregistrement DNS principaux:

A	Enregistrements d'adresses faisant correspondre un nom d'hôte à une adresse IPv4
CNAME	Enregistrements canoniques créant un alias d'un domaine vers un autre
MX	Définit les serveurs de messagerie pour le domaine
PTR	Associe une adresse IP à un enregistrement de nom de domaine

Recon-ng

Outil de reconnaissance Web avec de multiples modules.

- Enumération de sous domaines...



Panoplie Google

Google lens : <https://lens.google/intl/fr/>

Google Maps : <https://www.google.fr/maps>

Google Earth : <https://www.google.fr/intl/fr/earth>





Exercice 1 : Googlez-vous !

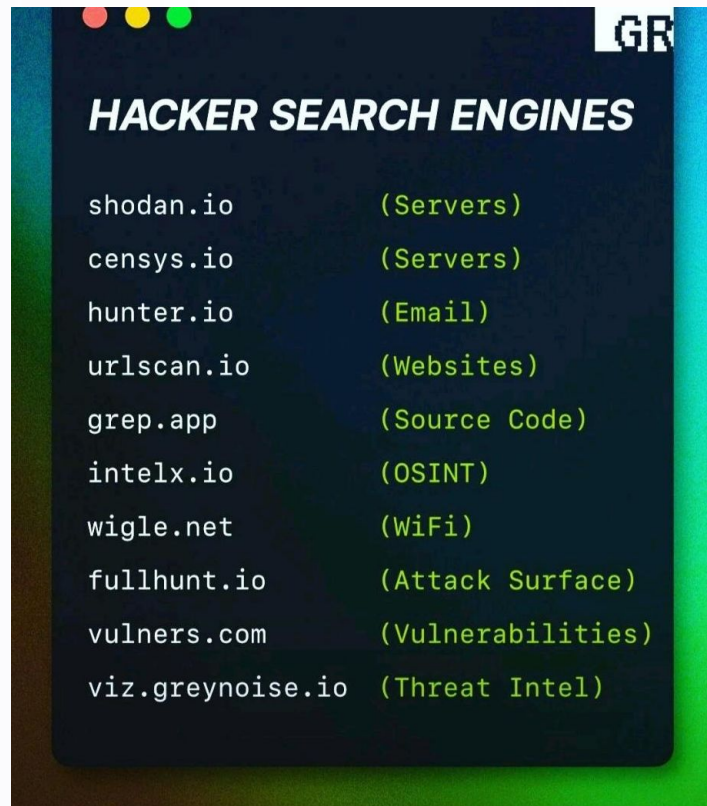


Shodan

- Moteur de recherche avancé
- Scan l'internet et recense tout objet connecté
 - Serveurs, routeurs, caméras...

L'utilisation de shodan se fait sur : <https://www.shodan.io/>





[Shodan](#) [Maps](#) [Images](#) [Monitor](#) [Developer](#) [More...](#)

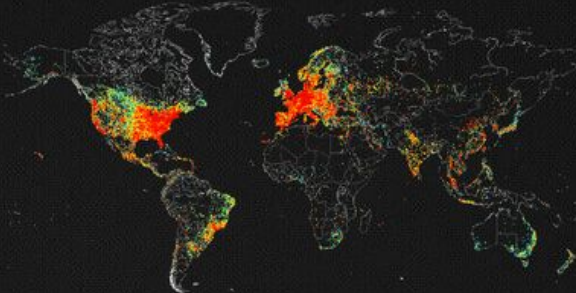
 **SHODAN** [Explore](#) [Pricing](#) 

[Login](#)

Search Engine for the Internet of Everything

Shodan is the world's first search engine for Internet-connected devices. Discover how Internet intelligence can help you make better decisions.

[SIGN UP NOW](#)



Shodan - Cheat Sheet

Common General Search Filters

ip:	Filter results by specific IP address.
asn:	Filter results by specific ASN ID.
hostname:	Filter results by specific hostname.
port:	Filter results by specific port number of service.
net:	Filter results from specified CIDR block.
isp:	Filter results by devices assigned a particular address (space) from a specified ISP.
city:	Filter results by specific city.
country:	Filter results by specific two-digit country code.
os:	Filter results by particular OS.
product:	Filter results by particular software.
version:	Filter results by specified version of software.

Common CLI Commands

count	Returns the number of results for a search.
domain	View all available information for a domain.
download	Download search results and save them in a compressed JSON file.
honeyscore	Check whether the IP is a honeypot or not.
host	View all available information for an IP address.
parse	Extract information out of compressed JSON files.
scan	Scan an IP/ netblock using Shodan.
search	Search the Shodan database.

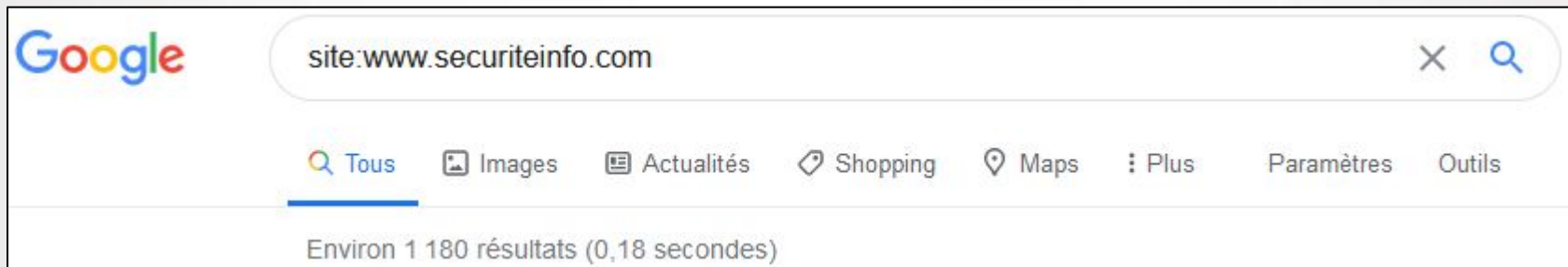


Exercice 2 : Shodan



Utilisation intelligente du moteur de recherche Google afin de trouver des fuites d'informations sensibles d'une entité.

- Exemples :
 - `site:www.securiteinfo.com`



Google Dorks (Opérateurs)

Opérateur	Description	Exemple d'utilisation
site	retourne les fichiers localisés sur un domaine particulier	iprec trouvera toutes les pages contenant le mot iprec dans le domaine
inurl	suivi par une phrase donnée retourne tous les résultats avec cette même phrase placée dans l'URL	inurl:iprec trouvera les pages contenant le mot iprec dans l'adresse URL
Intext	suivi du mot ou de la phrase que vous recherchez renvoie tous les résultats où la phrase ou le texte sont présents dans le texte d'une page web	intitle:iprec trouvera les pages contenant le mot iprec seulement dans le texte



Exercice 3/4 : Google Dorks & OSINT





Prise d'empreinte active (fingerprinting)

Qu'est ce que l'énumération ?

- Communiquer avec l'ensemble des équipements afin de recueillir plus d'information sur la cible.
- L'attaquant peut utiliser ces informations afin d'identifier les points d'entrées et tenter d'obtenir un accès non-autorisé aux ressources.
- L'énumération est généralement réalisée dans un environnement intranet de l'organisation cible.

Prise d'empreinte d'OS

Fingerprinting d'OS passif

- Identifier les types de systèmes d'exploitation utilisés par les machines cibles en écoutant uniquement le réseau (**aucun paquet n'est transmis**)

Fingerprinting d'OS actif

- Identifier les types de systèmes d'exploitation utilisés par les machines cibles en échangeant des paquets.

Scan de ports

Un scan des machines présentes sur le réseau est réalisé afin d'essayer de cartographier le réseau ainsi que les ports ouverts sur les machines.

- Détection des routeurs, firewall, serveurs...

L'outil de prédilection de balayage réseau est "Nmap".

- Attention: Tout acte de balayage réseau non autorisé est considéré comme une attaque et donc répréhensible par les lois vu précédemment.

Scan de ports

- NMAP Commands

Objectif	Command	Example
Scanner une seule cible	nmap [target]	nmap 192.168.0.1
Scanner plusieurs cibles	nmap [target1, target2, etc	nmap 192.168.0.1 192.168.0.2
Scanner une plage d'hôtes	nmap [range of ip addresses]	nmap 192.168.0.1-10
Scanner un sous réseau entier	nmap [ip address/cdir]	nmap 192.168.0.1/24

Scan de ports

- NMAP Commands

Objectif	Command	Example
Effectuer une analyse agressive	<code>nmap -A [target]</code>	<code>nmap -A 192.168.0.1</code>
Scannez sans ping	<code>nmap -Pn [target]</code>	<code>nmap -Pn 192.168.0.1</code>
Effectuez un ping	<code>nmap -sP [target]</code>	<code>nmap -sP 192.168.0.1</code>
Effectuez un traceroute	<code>nmap --traceroute [target]</code>	<code>nmap --traceroute [target]</code>

Scan de ports

- NMAP Commands Advanced Scan

Objectif	Command	Example
TCP SYN Scan	<code>nmap -sS [target]</code>	<code>nmap -sS 192.168.0.1</code>
TCP NULL Scan	<code>nmap -sN [target]</code>	<code>nmap -sN 192.168.0.1</code>
TCP FIN Scan	<code>nmap -sF [target]</code>	<code>nmap -sF 192.168.0.1</code>
TCP ACK Scan	<code>nmap -sA [target]</code>	<code>nmap -sA 192.168.0.1</code>
TCP Scan personnaliser	<code>nmap --scanflags [flags] [targets]</code>	<code>nmap --scanflags SYNFIN 192.168.0.1</code>

Scan de ports

- NMAP Commands Advanced Scan

Objectif	Command	Example
Détection system d'exploitation	<code>nmap -O [target]</code>	<code>nmap -O 192.168.0.1</code>
Détection de la version des services	<code>nmap -sV [target]</code>	<code>nmap -sV 192.168.0.1</code>
Obtenir de l'aide	<code>nmap -h</code>	<code>nmap -h</code>
Sortie détaillée	<code>nmap -V</code>	<code>nmap -V</code>



Exercice 5 : Enumération et scan NMAP





L'ingénierie sociale



Qu'est ce que l'ingénierie sociale ?

L'ingénierie sociale est l'art de convaincre les gens de révéler des informations confidentielles. Les objectifs communs de l'ingénierie sociale incluent le personnel du centre d'assistance, les responsables de l'assistance technique, les administrateurs système, etc...

- Il est difficile de se défendre contre l'ingénierie sociale, car la nature humaine est imprévisible. Il est impossible de savoir qui tombera dans le piège d'une attaque d'ingénierie sociale.
- Les impacts :

Pertes économiques

Procès et arbitrages

Fermeture temporaire ou permanente

Perte d'intimité

Domage

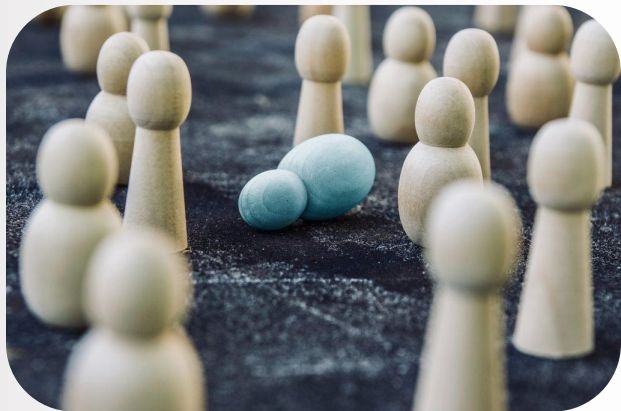
Danger de terrorisme

Les comportements vulnérables aux attaques

- La confiance en la nature humaine est la base de toute attaque d'ingénierie sociale.
- La méconnaissance de l'ingénierie sociale et de ses effets sur le personnel fait de l'organisation une cible facile.
- Peur de graves pertes en cas de non-respect de la demande de l'ingénieur social.
- Les ingénieurs sociaux attirent les cibles pour divulguer des informations en promettant quelque chose pour rien.
- On demande de l'aide aux cibles et elles se conforment par sens de l'obligation morale.

Les facteurs qui rendent les entreprises vulnérables aux attaques

- Formation de sécurité insuffisante.
- Accès non réglementé à l'information.
- Plusieurs unités d'organisation.
- Manque de politiques sécuritaires.



Exemple : Le support technique, une mine d'information

Les services de support technique des entreprises constituent une cible de choix pour les pirates, qui collectent des informations préalablement à leur attaque. La plupart des employés ont naturellement tendance à vouloir aider les interlocuteurs qui les contactent, témoigne-t-il. Il faut leur apprendre à refuser les demandes susceptibles de compromettre la sécurité.

Pourquoi l'ingénierie sociale est-elle efficace ?

- Les politiques de sécurité sont aussi fortes que leur lien le plus faible, et les humains sont les facteurs les plus faibles.
- Il est difficile de détecter les tentatives d'ingénierie sociale.
- Il n'y a aucune méthode pour assurer une sécurité complète contre les attaques d'ingénierie sociale.
- Il n'y a pas de logiciel ou de matériel spécifique pour se défendre contre une attaque d'ingénierie sociale.

Récupérer des informations = être une arme de guerre

Les phases d'attaques de l'ingénierie sociale

- Recherche sur l'entreprise cible :
 - Dans les poubelles (Dumpster Diving), sur les sites web, employés, tour de l'entreprise, etc ...
- Sélectionner une victime
 - Identifier les employés frustrés de l'entreprise cible
- Développer une complicité, une relation
 - Développer des relations avec les employés sélectionnés
- Exploiter cette complicité
 - Collecter des informations financières et de compte sensibles ainsi que les technologies actuelles

Les méthodes (ISH): Usurpation d'identité

- Il s'agit de la technique d'ingénierie sociale basée sur l'humain la plus courante dans laquelle l'attaquant prétend être une personne légitime ou autorisée.
- Les attaquants peuvent usurper l'identité d'une personne légitime ou autorisée, soit personnellement, soit en utilisant un moyen de communication tel que téléphone, courrier électronique, etc..
- L'emprunt d'identité aide les attaquants à tromper une cible pour révéler des informations sensibles.

Les méthodes (ISH) : Imitation

- Se faire passer pour un utilisateur final légitime
 - Donner son identité et poser la question qui mènera à l'obtention de l'information voulue.
- Se faire passer pour utilisateur important
 - On se fait passer pour une personne importante ou un gros client pour l'entreprise etc...
- Se faire passer pour le support technique
 - Appeler en temps que membre du staff support technique et demander les ID et mots de passe pour récupérer les données.

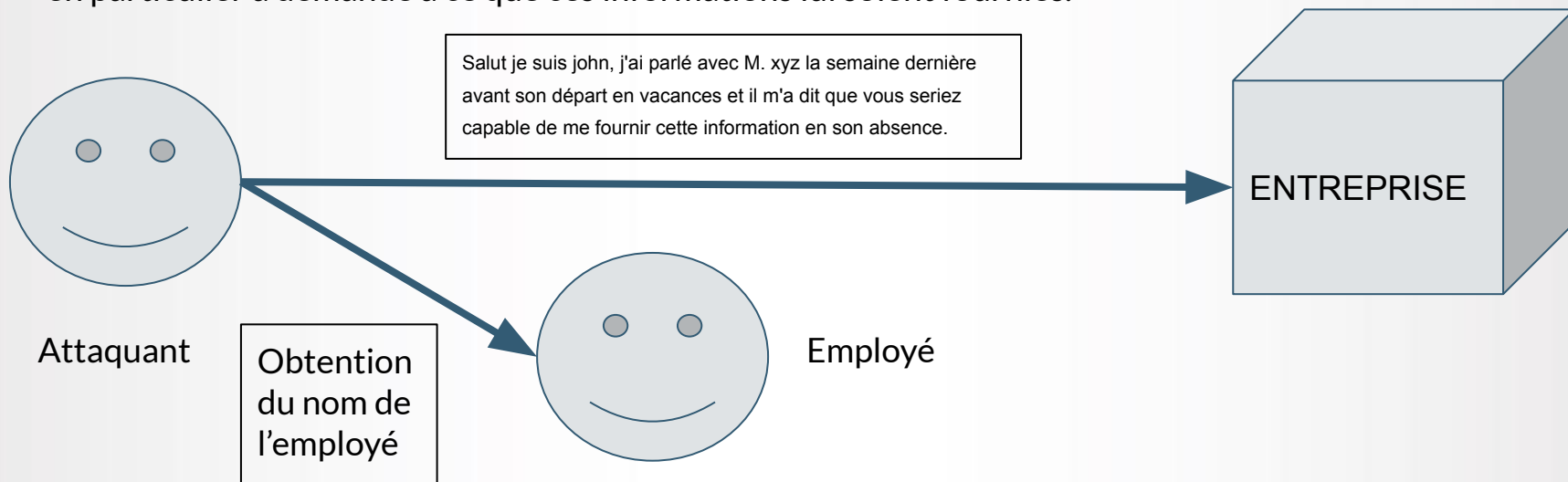
Les méthodes (ISH) : Imitation - Exemple de scénario | Centre d'assistance

- Les centres d'assistance sont souvent très vulnérables à l'ingénierie sociale puisque leur travail est explicitement d'aider.
- L'attaquant appelle le centre d'une entreprise, fait semblant d'être une personne en position d'autorité ou de pertinence et tente d'extraire des informations sensibles du service d'assistance.

Un homme appelle le centre d'assistance et dit qu'il a oublié son mot de passe. Il ajoute également que s'il ne respecte pas les délais de son projet publicitaire, son patron le licencie. Les personnes travaillant au centre d'assistance vont se sentir désolées pour lui et réinitialiser rapidement son mot de passe, donnant ainsi indirectement la porte d'entrée du réseau à l'attaquant.

Les méthodes (ISH) : Imitation - Exemple de scénario | Autorisation des tiers

- L'attaquant obtient le nom de l'employé autorisé de l'organisation cible qui a accès aux informations qu'il souhaite.
- L'attaquant appelle ensuite l'organisation cible où les informations sont stockées et affirme qu'un employé en particulier a demandé à ce que ces informations lui soient fournies.



Les méthodes (ISH) : Imitation - Exemple de scénario | Tech Support

- L'attaquant fait semblant d'être un membre du personnel du support technique des vendeurs/fournisseurs de logiciels de l'organisation cible.
- Il peut alors réclamer l'ID utilisateur et le mot de passe pour résoudre le problème de l'entreprise/organisation.

Attaquant : “Salut, c'est Jean-mi du support technique, certaines personnes de votre bureau ont signalé des ralentissements lors de la connexion récemment.

Est-ce vrai ?

Employé : “Oui, elle a semblé lente récemment”

Attaquant : “Nous vous avons déplacés vers un nouveau serveur, le service devrait être meilleur maintenant ! si vous voulez bien me donner votre mot de passe pour le vérifier. Tout devrait être résolu maintenant.”

Les méthodes (ISH) : Imitation - Exemple de scénario | Le réparateur

- L'attaquant peut prétendre être un réparateur de téléphone ou un technicien en informatique et entrer dans l'organisation cible.
- Il peut ensuite installer un dispositif d'espionnage ou obtenir des mots de passe cachés lors d'activités liées à leurs tâches.



Les méthodes (ISH) : Écoute / Shoulder Surfing

Écoute :

- L'écoute non autorisée de conversation ou la lecture de messages.
- Interception de messages audio, vidéo ou de communications écrites.
- Cela peut être fait en utilisant des chaînes de communication comme des lignes téléphoniques, des mails, des messageries instantanées, etc...

Shoulder Surfing :

- Le shoulder surfing utilise des techniques d'observation directes comme le fait de regarder l'écran d'une personne par dessus son épaule dans le but d'avoir des informations comme son mot de passe, son numéro de compte, etc...
- Le shoulder surfing peut aussi être réalisé à longue distance grâce à des outils d'observation longue distance comme des jumelles pour obtenir des informations sensibles.

Les méthodes (ISH) : Écoute / Shoulder Surfing

Écoute :

- L'écoute non autorisée de conversation ou la lecture de messages.
- Interception de messages audio, vidéo ou de communications écrites.
- Cela peut être fait en utilisant des chaînes de communication comme des lignes téléphoniques, des mails, des messageries instantanées, etc...

Shoulder Surfing :

- Le shoulder surfing utilise des techniques d'observation directes comme le fait de regarder l'écran d'une personne par dessus son épaule dans le but d'avoir des informations comme son mot de passe, son numéro de compte, etc...
- Le shoulder surfing peut aussi être réalisé à longue distance grâce à des outils d'observation longue distance comme des jumelles pour obtenir des informations sensibles.

Les méthodes (ISH) : Inverse / PiggyBacking / Tailgating

Inverse :

- Une situation dans laquelle un attaquant se présente en prétendant être un supérieur de la cible. Ce dernier voulant des conseils donnera les réponses aux questions de l'attaquant sans hésitation.

PiggyBacking :

- “J’ai oublié mon badge à la maison. S’il vous plaît aidez-moi.”
- Une personne autorisée permet à une personne non-autorisée de passer à travers la sécurité.

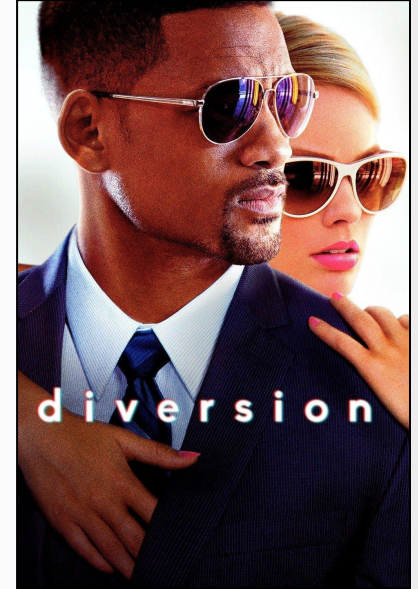
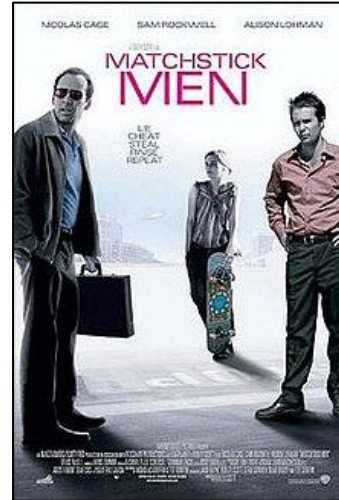
Tailgating :

- Une personne non autorisée, portant un faux badge, entre dans une zone en suivant de près une personne qui a l'accès.

Films qui s'appuie sur l'ingénierie sociale

- Diversion (Will Smith, Margot Robbie)
- La casa de papel
- Matchstick Men (Nicolas Cage)
- Catch me if you can (Leonardo Dicaprio, Tom Hanks)
- The italian Job

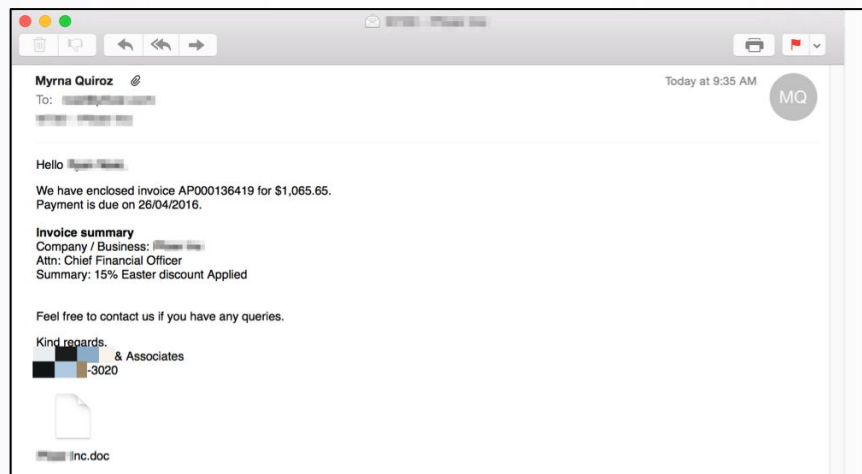
LA CASA DE PAPEL



- **Fenêtres pop-up :**
 - Fenêtres qui apparaissent soudainement pendant le surf sur internet et demande d'informations sur l'utilisateur pour s'inscrire ou se connecter.
- **Lettres canular :**
 - Les lettres de canular sont des courriels qui avertissent l'utilisateur de nouveaux virus, chevaux de Troie ou des worms susceptibles de nuire au système de l'utilisateur.
- **Lettre en chaîne :**
 - Les lettres en chaîne sont des courriels qui offrent des cadeaux gratuits comme de l'argent ou des logiciels à condition que l'utilisateur fasse passer le mail à un nombre donné de personnes.
- **Messagerie instantanée :**
 - Collecter des informations personnelles en parlant sur une messagerie instantanée avec une personne ciblée afin d'obtenir des informations comme les dates d'anniversaire ou le nom de jeune fille.
- **Spam :**
 - Courriel non pertinent, non désiré et non sollicité pour collecter des informations financières, des numéros de sécurité sociale et des informations de réseau.

Ingénierie sociale Informatique (ISI) : Le phishing

- Un e-mail illégitime prétendant faussement provenir d'un site légitime tente d'acquérir les informations personnelles ou de compte de l'utilisateur.
- Les emails de phishing ou les pop-ups redirigent l'utilisateur vers de fausses pages web qui imitent de vraies pages web possédant déjà la confiance de leurs utilisateurs. Ces pages leur demandent de rentrer des informations personnelles afin de les récupérer et de les utiliser.



Ingénierie sociale Informatique (ISI) : L'Hameçonnage

- Le spear phishing ou hameçonnage en français, est une attaque directe et ciblée vers des individus spécifiques appartenant à une entreprise/organisation.
- Contrairement aux attaques de phishing classiques où les attaquants envoient des centaines de messages génériques à des adresses électroniques aléatoires, ils utilisent le spear phishing pour envoyer un message contenant du contenu spécialisé d'ingénierie sociale destiné à une personne spécifique ou à un petit groupe de personnes.
- Le spear phishing génère un meilleur taux de réponse comparé au phishing normal.



Exercice 1 : Mon gentil mail !



Ingénierie sociale Mobile (ISM)

- Les attaquants créent des applications malveillantes avec des fonctionnalités intéressantes et des noms ressemblant à des applications populaires, et les publient sur les app stores les plus importants.
- Les utilisateurs non-avertis téléchargent des applications et se font infecter par des virus qui fournissent des informations d'identité aux attaquants.



Ingénierie sociale Mobile (ISM) : Fausses applications de sécurité

- L'attaquant infecte le système de la victime.
- La victime se connecte sur son compte bancaire.
- Le malware sur le pc fait apparaître un message demandant à la victime d'installer une application sur son téléphone pour recevoir des messages de sécurité.
- La victime télécharge l'application malveillante sur son téléphone.
- L'attaquant peut maintenant accéder à la 2eme authentification bancaire envoyée par SMS.

Ingénierie sociale Mobile (ISM) : Le SMS

1	La personne reçoit un sms, croyant qu'il vient du département sécurité de XIM Bank.
2	Il prétend que c'est urgent et demande à la personne d'appeler le numéro donné dans le sms immédiatement. Inquiète, la personne appelle le numéro de téléphone.
3	Elle appelle en croyant recevoir le service client de la banque, mais il s'agit d'un message enregistré lui demandant ses informations bancaires pour vérifier son compte en banque.
4	La personne révèle donc ses informations bancaires et l'attaquant n'a plus qu'à les récupérer.

Ingénierie social : Les attaques diverses (1)

Espionnage :

- Si un concurrent veut causer des dommages à votre entreprise, voler des secrets importants, ou vous sortir du marché, il n'a qu'à attendre une offre d'emploi, préparer quelqu'un pour l'entretien, le faire embaucher et il sera dans l'entreprise.

Vengeance :

- Il ne suffit que d'une seule personne mécontente qui désire se venger et votre entreprise est compromise.

Attaque Interne :

- Une attaque interne est facile à effectuer
- La prévention contre ce type d'attaque est difficile
- Cette attaque peut facilement être réussie

Ingénierie social : Les attaques diverses (2)

L'employé mécontent :

- Un employé peut devenir mécontent de l'entreprise quand on lui manque de respect, on le frustre avec son métier, des conflits avec ses supérieurs, il n'est pas satisfait des avantages de son emploi, on lui émet un avis de cessation d'emploi, on le transfère, etc...
- Il est possible que ces employés mécontents divulguent des secrets d'entreprise ou des propriétés intellectuelles à des concurrents contre de l'argent.



Objectifs communs d'ingénierie sociale

Cibles d'ingénierie sociale	Techniques d'attaque
Bureau d'accueil et bureau d'assistance	écoute, shoulder surfing, imitation, persuasion et intimidation
Périmètre de sécurité	imitation, fausses identités, piggybacking, etc.
Bureau	Shoulder surfing, écoute, séduction, etc.
Bureau d'assistance (téléphone)	Imitation, intimidation, et persuasions sur le bureau d'assistance téléphonique
Salle de courrier	vol, dommages, falsification de mails
Salle des machines/téléphones	Tentative d'avoir l'accès, enlever les équipements,

Ingénierie Sociale : Emprunt d'identité sur des sites de réseaux sociaux

- Les utilisateurs malveillants collectent des informations confidentielles à partir des réseaux sociaux et créent des comptes avec d'autres noms.
- Les attaquants utilisent d'autres profils pour de grands réseaux d'amis et extraient des informations à ces personnes en utilisant l'ingénierie sociale.
- Les attaquants tentent de rejoindre les groupes d'employés de l'organisation cible où ils partagent des informations personnelles et professionnelles.
- Les assaillants peuvent également utiliser les informations collectées pour mener à bien d'autres formes d'attaques d'ingénierie sociale.

Ingénierie Sociale : Les réseaux sociaux : Facebook

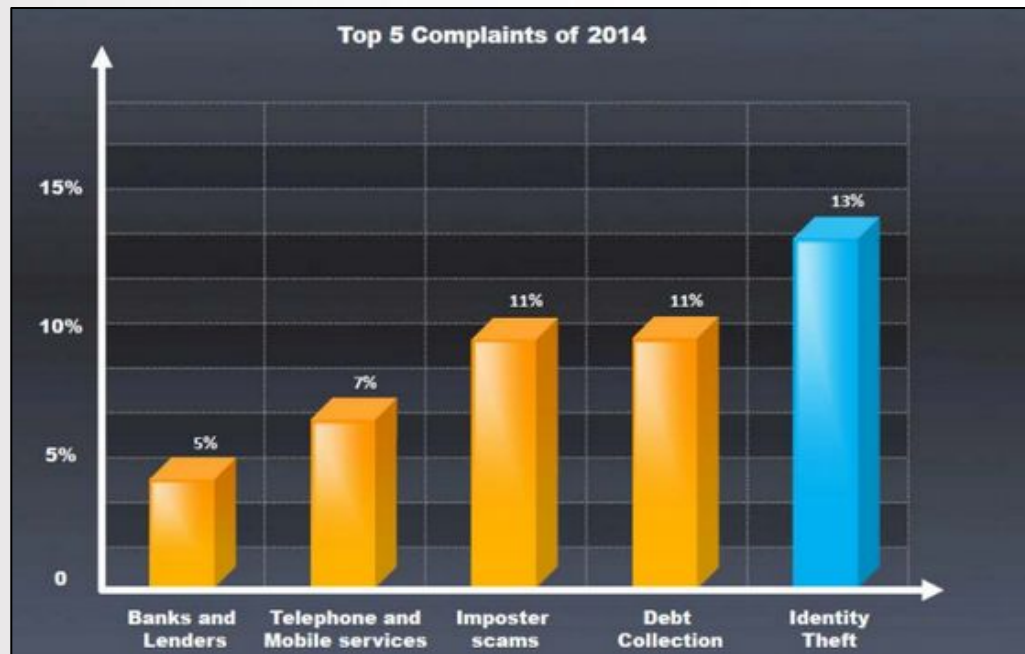
- Les attaquants créent un groupe de faux utilisateurs sur Facebook, identifiés comme “Travaillant” dans l’entreprise ciblée.
- En utilisant une fausse identité, l’attaquant procède à une invitation des employés au faux groupe, “employés de l’entreprise”.
- Les utilisateurs rejoignent le groupe et donnent les informations personnelles.



Ingénierie Sociale : Autres réseaux sociaux



Ingénierie Sociale : Le vol d'identité - statistique



Comparaison maintenant :

- Identity theft – 65%
- Account access – 17%
- Financial access – 13%
- Nuisance – 4%
- Existential data – 1%

Ingénierie Sociale : Le vol d'identité - explications

- Le vol d'identité se produit lorsque quelqu'un vole vos informations personnellement identifiables à des fins frauduleuses.
- C'est un délit pour lequel un imposteur obtient des informations d'identification telles que nom, numéro de carte de crédit, numéro de sécurité sociale ou de permis de conduire, etc. pour commettre une fraude ou tout autre crime.
- Les attaquants peuvent utiliser le vol d'identité pour usurper l'identité d'employés d'une organisation cible et accéder physiquement à l'installation.

Le vol d'identité est puni par la loi :

L'article 226-4-1 réprime le délit d'usurpation d'identité en sanctionnant d'un an de prison et de 15 000 euros d'amende: "
Le fait d'usurper l'identité d'un tiers ou de faire usage d'une ou plusieurs données de toute nature permettant de l'identifier en vue de troubler sa tranquillité ou celle d'autrui, ou de porter atteinte à son honneur ou à sa considération »



Exercice 2 : Acme Corp !





Les contres mesures



Contre-mesures à l'ingénierie sociale (1)

- Les bonnes politiques et procédures sont inefficaces si elles ne sont pas enseignées et renforcées par les employés.
- Après avoir suivi une formation, les employés doivent signer une déclaration reconnaissant qu'ils comprennent les politiques.

Politiques de mot de passe

- Changement de mots de passe régulièrement.
- Éviter les mots de passe devinables.
- Bloquer les comptes après des tentatives ratées.
- Taille et complexité des mots de passe.
- Secret des mots de passe.

Politiques de sécurité physique

- Identification des employés à l'aide d'une pièce d'identité, d'uniformes, etc...
- Escorter les visiteurs.
- Restrictions des zones d'accès.
- Déchiquetage approprié des documents inutiles.
- Employer du personnel de sécurité.

Contre-mesures à l'ingénierie sociale (2)

- **Formation** : un programme de formation efficace devrait comprendre toutes les politiques et méthodes de sécurité pour accroître la sensibilisation à l'ingénierie sociale.
- **Directives opérationnelles** : assurez-vous que les informations sensibles sont sécurisées et que les ressources ne sont accessibles qu'aux utilisateurs autorisés.
- **Privilèges d'accès** : il devrait y avoir des comptes administrateurs, utilisateurs et invités possédant les autorisations appropriées.
- **Classification des informations** : catégoriser les informations comme top secret, convenance, pour usage interne uniquement, pour usage public, etc...
- **Temps de réponse correct** : il devrait y avoir des directives appropriées pour réagir en cas de tentative d'ingénierie sociale.
- **Vérification des antécédents et processus de résiliation approprié** : les initiés ayant un casier judiciaire et les employés licenciés sont des cibles faciles pour l'obtention d'informations.

Contre-mesures à l'ingénierie sociale (3)

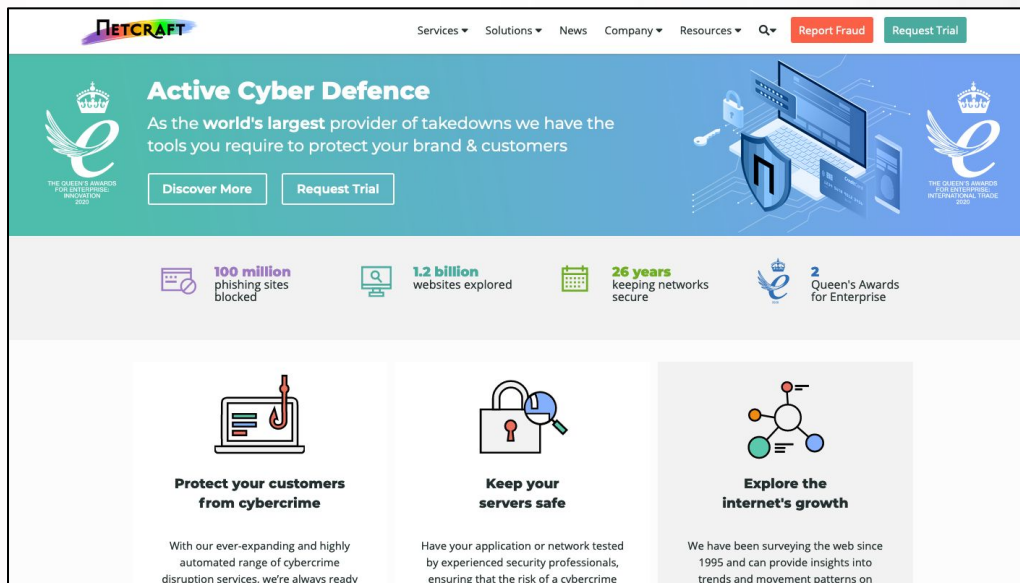
- Anti-Virus/Défenses anti-phishing : Utiliser plusieurs couches de défenses antivirus au niveau de l'utilisateur final et de la passerelle de messagerie pour minimiser les attaques d'ingénierie sociale.
- Authentification double facteurs au lieu de mots de passe fixes, utiliser l'authentification à deux facteurs pour les services réseau à haut risque tels que les réseaux privés virtuels (VPN) et les pools de modems.
- Gestion de changements : un processus documenté de gestion des modifications est plus sécurisé que le processus ad hoc.

Comment détecter les mails de phishing ?

- Semble provenir d'une banque, d'une entreprise ou d'un site de réseautage social et avoir un message d'accueil générique.
- Donne un sentiment d'urgence ou une menace voilée.
- Peut contenir des erreurs grammaticales ou d'orthographe.
- Inclut des liens vers des sites Web usurpés.
- Peut contenir des offres qui peuvent paraître faciles à croire.
- Inclut des logos ressemblant à des logos officiels et d'autres informations prises dans des sites ayant une légitimité déjà établie .
- Peut contenir une pièce jointe illicite.

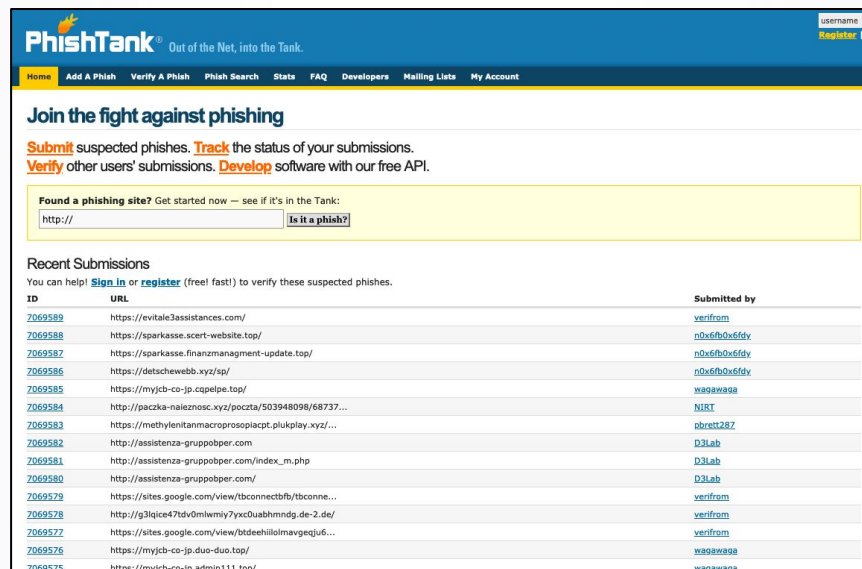
Barre d'outils anti-phishing : NetCraft

- La communauté anti-phishing de netcraft est en réalité un système de surveillance géant, permettant aux membres les plus alertes et les plus experts de défendre tous les membres de la communauté contre les attaques de phishing.



Barre d'outils anti-phishing : PhishTank

- Phishtank est un centre d'échange collaboratif de données et d'informations sur le phishing sur Internet.
- Il fournit une API ouverte permettant aux développeurs et aux chercheurs d'intégrer des données anti-phishing dans leurs applications.



PhishTank® Out of the Net, into the Tank.

Home Add A Phish Verify A Phish Phish Search Stats FAQ Developers Mailing Lists My Account

Join the fight against phishing

Submit suspected phishes. **Track** the status of your submissions.
Verify other users' submissions. **Develop** software with our free API.

Found a phishing site? Get started now — see if it's in the Tank:

Recent Submissions

You can help! [Sign in](#) or [register](#) (free! fast!) to verify these suspected phishes.

ID	URL	Submitted by
7069589	https://evitale3assurances.com/	verfrom
7069588	https://sparkasse.scert-website.top/	n0x6th0x6fdy
7069587	https://sparkasse.finanzmanagement-update.top/	n0x6th0x6fdy
7069586	https://detscheweibb.xyz/sp/	n0x6th0x6fdy
7069585	https://myjcb-co-jp.cqelpe.top/	ma9awaa
7069584	http://paczka-naiznosc.xyz/poczta/503948098/68737...	NIRT
7069583	https://methylenitanmacroprosiapt.plukplay.xyz/...	pbrent287
7069582	http://assistenza-gruppobper.com	D3lab
7069581	http://assistenza-gruppobper.com/index_m.php	D3lab
7069580	http://assistenza-gruppobper.com/	D3lab
7069579	https://sites.google.com/view/tbconnectbfb/tbconne...	verfrom
7069578	http://g3lqice47dv0mlwmiy7yxcDuabhmndg_de-2.de/	verfrom
7069577	https://sites.google.com/view/btdeehillomavgegu6...	verfrom
7069576	https://myjcb-co-jp.duo-duo.top/	ma9awaa
7069575	https://mwhch-co-in.admin1111-top/	ma9awaa

Contre-mesures au vol d'identité

- Sécuriser ou déchirer tous les documents contenant des informations privées.
- Liste de résultats des spécialistes du marketing.
- Examinez régulièrement vos rapports de carte de crédit et ne les laissez jamais disparaître de la vue.
- Ne jamais donner d'informations personnelles sur le téléphone.
- Pour garder votre email sécurisé, vider la boîte de réception rapidement.
- Suspecter et vérifier toutes les demandes de données personnelles.
- Protéger vos informations personnelles contre la publication.
- Ne pas afficher les numéros de compte / contact sauf si obligatoire.

A yellow L-shaped graphic element consisting of a horizontal line at the top and a vertical line on the right, forming an open square frame.

Fin du Module 2
IPREC

